

Prompt Injection 不是 AI 问题：为什么 MCP 工具层加固才是关键

作者：陈世强 (Shiqiang Chen) — 独立安全研究员

日期：2026 年 7 月 14 日

摘要

Prompt injection 被广泛讨论为 AI 安全问题。我们提出实验证据表明这种框架是不完整的。使用自定义 MCP 代理模拟器和一个存在真实漏洞的 MCP 服务器 (cherrystudio-qq-mcp)，我们证明：prompt 层过滤对注入攻击仅提供 50% 的防护，而 MCP 工具层的简单输入验证提供 100% 的防护。

核心发现

结论：Prompt 过滤仅在 50% 的情况下有效；MCP 工具层的 `validate_safe_path()` 在 100% 的攻击中阻止了注入。

实验设计

测试了 6 种 prompt injection 技术：直接注入、间接注入、编码绕过、多步注入、上下文污染、Unicode 混淆。

真实案例：cherrystudio-qq-mcp

- CWE-22 路径遍历：file_path 参数无 validate_safe_path() 验证
- CWE-918 SSRF：URL 参数无 validate_safe_url() 验证

实践建议

```
def validate_safe_path(path: str, base_dir: str) -> str:
    full = os.path.realpath(os.path.join(base_dir, path))
    if not full.startswith(os.path.realpath(base_dir)):
        raise SecurityError("Path traversal detected")
    return full
```

所有 MCP 工具应该在执行前调用此函数。

对应英文原版: [10.5281/zenodo.21370438](https://doi.org/10.5281/zenodo.21370438)